KnowledgeOS Enterprise Test Data — Data Privacy & Protection Policy

Field	Value
Version	2.8
Classification	INTERNAL - ALL EMPLOYEES
Effective Date	February 1, 2024
Last Reviewed	January 15, 2024
Document Owner	Data Protection Officer (DPO) / Chief Privacy Officer
Review Cycle	Semi-Annual
Regulatory References	GDPR (EU 2016/679), CCPA/CPRA (Cal. Civ. Code § 1798.100+), LGPD (Brazil Law 13.709), PDPA (Singapore 2012), PIPL (China), POPIA (South Africa), HIPAA, FERPA, GLBA

---

1. Purpose & Scope

This policy establishes TechGlobal Solutions Inc. ("Company," "we," "us," "our") commitment to protecting personal data and ensuring compliance with global data protection regulations. It applies to all processing of personal data by the Company, whether as Controller or Processor, across all jurisdictions where we operate.

Scope includes:

- All employees, contractors, third parties with access to personal data
- All systems, applications, databases, paper records, backups
- All processing activities: collection, storage, use, disclosure, transfer, deletion
- Customer data, employee data, candidate data, vendor data, website visitors

2. Data Protection Principles (GDPR Art. 5)

2.1 Lawfulness, Fairness & Transparency

- Legal basis identified for every processing activity (Art. 6 GDPR)
- Privacy notices provided at collection (Art. 13/14)
- No processing beyond disclosed purposes without new notice/consent

2.2 Purpose Limitation

- Data collected for specified, explicit, legitimate purposes
- Further processing compatible only if: archiving, research, statistics (with safeguards)

2.3 Data Minimization

- Adequate, relevant, limited to what is necessary
- Regular reviews to purge unnecessary data fields

2.4 Accuracy

- Reasonable steps to ensure accuracy; rectification without delay
- Data subjects can update via self-service portals

2.5 Storage Limitation

- Retained only as long as necessary per Records Retention Schedule
- Automated deletion/anonymization where feasible

2.6 Integrity & Confidentiality (Security)

- Technical & organizational measures per Section 8
- Encryption, pseudonymization, access controls, monitoring

2.7 Accountability

- DPO appointed; records of processing activities (ROPA) maintained
- DPIAs for high-risk processing; vendor DPAs; breach procedures

3. Legal Bases for Processing

3.1 Customer Data

- Contract performance (Art. 6(1)(b)): Service delivery, billing, support
- Legitimate interest (Art. 6(1)(f)): Product improvement, security, fraud prevention

- Consent (Art. 6(1)(a)): Marketing, analytics cookies, optional features
- Legal obligation (Art. 6(1)(c)): Tax, audit, regulatory reporting

3.2 Employee & Candidate Data

- Contract/pre-contract (Art. 6(1)(b)): Payroll, benefits, background checks
- Legal obligation (Art. 6(1)(c)): Tax, immigration, safety, EEO reporting
- Legitimate interest (Art. 6(1)(f)): Workforce analytics, security monitoring
- Consent: Voluntary programs (wellness, ERGs, photo directory)
- Special category (Art. 9): Health (benefits, accommodations), biometrics (access), union membership

3.3 Vendor/Partner Data

- Contract (Art. 6(1)(b)): Procurement, payments, performance management
- Legitimate interest: Vendor risk management, due diligence

4. Data Subject Rights

4.1 Rights Supported

Right	GDPR	CCPA/CPRA	Response SLA
Access	Art. 15	§ 1798.100	30 days (45 CA)
Rectification	Art. 16	§ 1798.105	30 days
Erasure ("Right to be Forgotten")	Art. 17	§ 1798.105	30 days
Restriction	Art. 18	—	30 days
Portability	Art. 20	§ 1798.130	30 days
Object	Art. 21	§ 1798.120	30 days
Not subject to automated decision-making	Art. 22	§ 1798.185	30 days
Opt-out of sale/sharing	—	§ 1798.120	15 days
Limit sensitive data use	—	§ 1798.121	15 days

4.2 Request Handling Process

1. Receive: privacy@techglobal.com, web form, mail, phone
2. Verify identity: Risk-based (email confirmation → government ID for sensitive)
3. Log: Privacy Request Tracker (ServiceNow) with SLA timer
4. Coordinate: Data owners across systems (Workday, Salesforce, Snowflake, etc.)
5. Execute: Fulfill or deny with written explanation
6. Confirm: Secure delivery (encrypted portal) + audit log
7. Appeal: Denials reviewed by DPO + Legal within 15 days

4.3 Exemptions

- Legal privilege, ongoing investigations, IP protection, disproportionate effort
- Documented in ROPA; subject to supervisory authority review

5. Consent Management

5.1 Consent Standards

- Freely given, specific, informed, unambiguous (GDPR Art. 4(11))
- Granular: Separate consent for each purpose (marketing, analytics, profiling)
- Easy withdrawal: Same mechanism as giving (one-click unsubscribe)
- No pre-ticked boxes; no bundling with T&Cs

5.2 Consent Records

- Stored: Timestamp, version of notice, mechanism, IP address, user agent
- Retained: Duration of processing + 3 years post-withdrawal
- Auditable: Consent dashboard for data subjects

5.3 Cookie Consent

- Categories: Strictly Necessary, Functional, Analytics, Advertising
- Banner: Geo-aware (GDPR/CCPA/LGPD variants)
- TCF 2.2 compliance for programmatic advertising

6. Cross-Border Data Transfers

6.1 Transfer Mechanisms (Priority Order)

1. Adequacy Decision: EU→US (DPF), UK, Canada, Japan, Israel, NZ, Switzerland, Uruguay, Argentina, Andorra, Faroe Islands, Guernsey, Isle of Man, Jersey

2. Standard Contractual Clauses (SCCs): 2021 EU SCCs + UK Addendum
3. Binding Corporate Rules (BCRs): In progress (target 2025)
4. Derogations: Explicit consent, contract necessity, vital interests (exceptional)

6.2 Transfer Impact Assessments (TIAs)

- Required for all SCC transfers to non-adequate countries
- Assess: Laws of destination, supplementary measures, importer obligations
- Documented in ROPA; reviewed annually or on legal change

6.3 Restricted Jurisdictions

- China (PIPL): Local storage required for critical data; security assessment for export
- Russia: Localization law (152-FZ) — Russian citizen data stored in RF
- US: DPF certification for US entities; SCCs + supplementary measures for others

7. Data Protection Impact Assessments (DPIAs)

7.1 When Required (GDPR Art. 35)

- Systematic profiling with significant effects
- Large-scale special category data processing
- Large-scale public monitoring
- New technologies (AI/ML, biometrics, IoT)
- High-risk per EDPB guidelines (WP248)

7.2 DPIA Process

1. Screening: Project intake form → Privacy team determines need
2. Assessment: DPIA template (description, necessity, risks, measures)
3. Consultation: DPO + Security + Legal + Business Owner
4. Mitigation: Technical/organizational measures with owners/dates
5. Sign-off: DPO approval; high residual risk → Supervisory Authority consultation
6. Monitor: Annual review or on material change

7.3 AI/ML Specific DPIAs

- Training data provenance, bias testing, explainability, human review
- Model cards documented; retraining triggers re-assessment

8. Technical & Organizational Measures (TOMs)

8.1 Access Control

- Role-based access (RBAC) with least privilege
- Quarterly access reviews (managers + data owners)
- Privileged access: PAM (CyberArk), session recording, break-glass
- MFA for all personal data access

8.2 Encryption

- At rest: AES-256 (databases, files, backups, laptops)
- In transit: TLS 1.2+ (mutual TLS for service-to-service)
- Key management: AWS KMS / Azure Key Vault / HashiCorp Vault (HSM-backed)
- Email: Office 365 Message Encryption for CONFIDENTIAL/RESTRICTED

8.3 Pseudonymization & Anonymization

- Tokenization: Production → Non-prod (Format-preserving encryption)
- Synthetic data: Generated for ML training (Gretel/Mostly AI)
- K-anonymity ($k \geqslant 5$), l-diversity, t-closeness for analytics datasets

8.4 Data Loss Prevention (DLP)

- Network: Forcepoint/Zscaler (email, web, cloud)
- Endpoint: Microsoft Purview / CrowdStrike
- Classification: Regex, dictionary, ML classifiers (PII, PHI, PCI, secrets)
- Actions: Block, encrypt, quarantine, alert, user justification

8.5 Logging & Monitoring

- Personal data access logged (who, what, when, why)
- SIEM correlation: Splunk + Chronicle
- Anomaly detection: UEBA for excessive access, off-hours, geo-impossible
- Retention: 13 months hot / 7 years cold

9. Vendor & Third-Party Management

9.1 Data Processing Agreements (DPAs)

- Required for ALL processors (Art. 28 GDPR)
- Standard DPA template (Company favorable); negotiations tracked
- Sub-processors: Prior written authorization; flow-down terms
- International transfers: SCCs embedded in DPA

9.2 Vendor Privacy Assessment

- Tier 1 (High): Access to personal data → Full privacy assessment + DPA + annual review
- Tier 2 (Medium): Limited access → Abbreviated assessment + DPA
- Tier 3 (Low): No personal data → Standard contract clauses only
- Assessment: Security questionnaire, certifications (SOC 2, ISO 27001), breach history

9.3 Onboarding & Offboarding

- Onboarding: Privacy review → DPA execution → Access provisioning → Monitoring
- Offboarding: Data return/destruction certification → Access revocation → Audit

10. Records of Processing Activities (ROPA)

10.1 Controller ROPA (Art. 30(1))

- Categories: HR, CRM, Marketing, Finance, Product, Security, Legal
- Fields: Purpose, legal basis, categories of data/subjects, recipients, transfers, retention, TOMs

10.2 Processor ROPA (Art. 30(2))

- Per customer agreement: Categories, purposes, transfers, TOMs

10.3 Maintenance

- Platform: OneTrust / TrustArc (automated discovery + manual enrichment)
- Updates: Quarterly business review + change-triggered (new system, new purpose)
- Export: Available for supervisory authority on request

11. Data Retention & Disposal

11.1 Retention Principles

- Legal requirement > Contractual > Business need > Consent
- Minimum necessary period; anonymize when identification no longer needed

- Legal hold overrides retention schedule

11.2 Key Retention Periods

Data Category	Retention Period	Basis
Customer contracts	7 years post-termination	Contract law, SOX
Employee records	7 years post-separation	FLSA, Title VII, ADEA
Payroll/tax	7 years	IRS, SSA
Marketing leads	3 years from last engagement	Legitimate interest
Website analytics	26 months (GA4 default)	Consent/legitimate int.
Security logs	13 months / 7 years	SOC 2, incident response
Candidate data (rejected)	3 years (US) / 6 months (EU)	EEOC / GDPR
Call recordings	2 years (regulated: 7 years)	MiFID II, Dodd-Frank

11.3 Disposal Methods

- Digital: Cryptographic erasure (key destruction) + verification
- Physical: Cross-cut shred (NIST 800-88), pulping, incineration
- Certification: Destruction certificates for all media

12. Data Breach Management

12.1 Breach Definition

- Confidentiality: Unauthorized access/disclosure
- Integrity: Unauthorized alteration
- Availability: Accidental loss/destruction (ransomware, outage > 4 hrs)

12.2 Notification Timelines

- Supervisory Authority: 72 hours from awareness (GDPR Art. 33)
- Data Subjects: Without undue delay if high risk (Art. 34)
- CCPA: "In the most expedient time possible" (practical: 72 hours)
- Regulators: Sector-specific (HIPAA 60 days, NYDFS 72 hours, etc.)

12.3 Breach Response Process

1. Detect & Contain (0-4 hrs): IR team, isolate systems, preserve evidence
2. Assess (4-24 hrs): Scope, data types, subjects affected, risk level
3. Notify (24-72 hrs): DPO → Legal → Executive → Regulators → Subjects
4. Remediate: Root cause, patches, enhanced monitoring, user comms
5. Lessons Learned: Post-mortem within 14 days; improvements tracked

12.4 Breach Register

- All incidents logged (including near-misses)
- Fields: Date, description, categories, subjects, risk, notifications, status
- Annual summary to Board Audit Committee

13. Privacy by Design & Default

13.1 System Development Lifecycle (SDLC)

- Privacy requirements in Epic/Feature definition
- Threat modeling: STRIDE + LINDDUN (privacy-specific)
- Code review: Privacy checklist (data minimization, encryption, logging)
- Pre-production: DPIA gate for high-risk features
- Production: Privacy regression tests in CI/CD

13.2 Default Settings

- Opt-out by default for non-essential processing
- Minimal data collection (progressive profiling)
- Shortest retention viable
- Access logs enabled by default

14. Children's Data

14.1 Age Verification

- Minimum age: 16 (GDPR) / 13 (CCPA/COPPA) for consent
- Age gate on registration; parental consent workflow for < 16/13
- No profiling or automated decision-making for children

14.2 Special Protections

- Enhanced data minimization
- No behavioral advertising
- Right to erasure prominently featured
- Parental dashboard for consent management

15. Training & Awareness

15.1 Mandatory Training

- All employees: Annual Privacy Essentials (30 min)
- Role-based: Engineering (Privacy by Design), Sales (Consent), HR (Employee Data), Support (DSR Handling)
- New hires: Within 30 days
- Completion: 95% target; tracked in LMS

15.2 Privacy Champions Network

- One per department; quarterly sync with Privacy Office
- First line for privacy questions; escalation to DPO

16. Governance & Oversight

16.1 Data Protection Officer (DPO)

- Independent reporting line to Board (Audit Committee)
- Resources: Privacy team (6 FTE), budget, tool access
- Tasks: Art. 39 GDPR (advise, monitor, cooperate, contact point)

16.2 Privacy Steering Committee

- Quarterly: CPO, CISO, CLO, CIO, VP Engineering, VP HR, VP Marketing
- Reviews: Metrics, incidents, regulatory developments, strategic initiatives

16.3 Metrics & Reporting

- DSR volume, SLA compliance, breach count/severity, training completion
- DPIA completion rate, vendor assessment coverage, ROPA currency
- Monthly dashboard; quarterly Board report

17. Related Policies & Documents

- Records Retention & Disposal Schedule
- Information Classification & Handling Policy
- IT Acceptable Use Policy
- Security Incident Response Plan
- Vendor Security & Privacy Assessment Policy
- Cookie Policy (External)
- Privacy Notices (Customer, Employee, Candidate, Website)
- Standard Contractual Clauses Template
- DPIA Template & Guidance
- Data Subject Request Procedure

18. Definitions

- **Controller:** Determines purposes/means of processing
- **Processor:** Processes on behalf of Controller
- **Personal Data:** Any information relating to identified/identifiable natural person
- **Special Category Data:** Art. 9 GDPR (health, biometric, racial, political, etc.)
- **PII:** Personally Identifiable Information (US term)
- **DPIA:** Data Protection Impact Assessment
- **ROPA:** Records of Processing Activities
- **DPF:** EU-US Data Privacy Framework
- **SCCs:** Standard Contractual Clauses
- **TIA:** Transfer Impact Assessment
- **BCRs:** Binding Corporate Rules
- **DPA:** Data Processing Agreement / Data Protection Authority
- **DPO:** Data Protection Officer
- **DSR:** Data Subject Request
- **PAM:** Privileged Access Management
- **UEBA:** User and Entity Behavior Analytics

19. Revision History

Version	Date	Author	Description

2.8	2024-02-01	DPO Office	Added AI/ML DPIA guidance, updated DPF, enhanced children's data, vendor tiers
2.7	2023-08-15	DPO Office	CPRA updates, TIA requirements, cookie consent TCF 2.2, synthetic data
2.6	2023-02-01	DPO Office	Post-Schrems II: TIAs, supplementary measures
2.5	2022-07-10	Privacy Team	LGPD/PIPL/POPIA coverage, vendor program

---

END OF DOCUMENT